

VULNSCAN LITE

Automated Web Security Posture & Vulnerability Health Audit

Target URL: example.com
Audit Date: 2026-09-30 14:19:36 UTC
Scan Reference ID: a1fa17cd-4387-47a2-bed8-47843b87dd7c
Assessment Mode: Passive Non-Intrusive Analysis

F
50 / 100

Critical Deficiencies

PASSED CHECKS 7	FAILED CHECKS 6	WARNINGS 1	TOTAL AUDITED 14
--------------------	--------------------	---------------	---------------------

Identified Tech Stack: Web Server: cloudflare
SSL/TLS Protocol: TLSv1.3 | TLS_AES_256_GCM_SHA384 (Issuer: SSL Corporation)
Cert Expiration: 2026-12-25T22:56:35+00:00 (86 days remaining)

Deficiencies & Remediation Action Plan

1. Content-Security-Policy (Header Analysis)

Finding: Security header 'Content-Security-Policy' is missing.
Risk Impact: High: Leaves site susceptible to Cross-Site Scripting (XSS), data injection, and clickjacking.

Nginx Remediation:
add_header Content-Security-Policy "default-src 'self'; script-src 'self' https://trustedscripts.com; style-src 'self' 'unsafe-inline'; img-src 'self' data:;" always;

Apache Remediation:
Header always set Content-Security-Policy "default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data:;"

2. Strict-Transport-Security (Header Analysis)

Finding: Security header 'Strict-Transport-Security' is missing.
Risk Impact: High: Attackers on same network can perform SSL-stripping and Man-in-the-Middle (MITM) attacks.

Nginx Remediation:
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" always;

Apache Remediation:
Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"

3. X-Frame-Options (Header Analysis)

Finding: Security header 'X-Frame-Options' is missing.
Risk Impact: Medium: Allows malicious actors to perform Clickjacking attacks by framing your website.

Nginx Remediation:
add_header X-Frame-Options "SAMEORIGIN" always;

Apache Remediation:
Header always set X-Frame-Options "SAMEORIGIN"

4. X-Content-Type-Options (Header Analysis)

Finding: Security header 'X-Content-Type-Options' is missing.

Risk Impact: Low: Browsers may execute non-executable files as scripts if MIME sniffing occurs.

Nginx Remediation:

add_header X-Content-Type-Options "nosniff" always;

Apache Remediation:

Header always set X-Content-Type-Options "nosniff"

5. Referrer-Policy (Header Analysis)

Finding: Security header 'Referrer-Policy' is missing.

Risk Impact: Low: Sensitive URLs containing tokens or session parameters might leak to 3rd-party sites.

Nginx Remediation:

add_header Referrer-Policy "strict-origin-when-cross-origin" always;

Apache Remediation:

Header always set Referrer-Policy "strict-origin-when-cross-origin"

6. Permissions-Policy (Header Analysis)

Finding: Security header 'Permissions-Policy' is missing.

Risk Impact: Low: Embedded 3rd party iframes or compromised scripts might access sensitive browser APIs.

Nginx Remediation:

add_header Permissions-Policy "camera=(), microphone=(), geolocation=(), payment=()" always;

Apache Remediation:

Header always set Permissions-Policy "camera=(), microphone=(), geolocation=(), payment=()"

Security Warnings & Observability

1. Information Disclosure Headers - Server leaks technology details in headers: Server: cloudflare

Risk: Attackers can tailor exploit payloads targeting the specific web server or runtime version revealed.

Passed Posture Verifications

Check Name	Category	Verification Note
HTTPS Protocol Enforced	Transport Security	Target communicates securely over HTTPS (https://example.com/).
SSL/TLS Certificate Validity	SSL/TLS Security	Valid certificate issued by trusted CA (SSL Corporation).
Certificate Expiration Date	SSL/TLS Security	Certificate is active with 86 days remaining until expiration.
Modern TLS Protocol Version	SSL/TLS Security	Server supports secure protocol TLSv1.3.
Cipher Suite Bit Strength	SSL/TLS Security	Strong encryption cipher negotiated: TLS_AES_256_GCM_SHA384 (256-bit keys).
CMS Generator Tag Concealed	Technology Fingerprinting	HTML generator meta tags are hidden or disabled.
Clean Application Surface	Technology Fingerprinting	No legacy CMS fingerprints detected. Custom or headless architecture.

LEGAL & COMPLIANCE DISCLAIMER: Only scan websites you own or have explicit authorization to test. This report is generated using passive inspection techniques (HTTP header inspection, SSL certificate verification, and public HTML meta parsing). No active exploitation, intrusive fuzzing, or invasive attack payloads were executed.